

PMForce: Systematically Analyzing PostMessage Handlers at Scale

PMForce: Systematically Analyzing PostMessage Handlers at Scale - Steffens, Marius, publications.cispa.saarland.

- Published: date not stated
- Original: <<https://publications.cispa.saarland/3164/>>
- Preserved from: <https://publications.cispa.saarland/3164/> (stored) on 2026-08-09
- Capture timestamp: 20200811035003
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

PMForce: Systematically Analyzing PostMessage Handlers at Scale - CISPA

PMForce: Systematically Analyzing PostMessage Handlers at Scale

Steffens, Marius and Stock, Ben

(2020) *PMForce: Systematically Analyzing PostMessage Handlers at Scale*.

In: ACM CCS 2020.

Conference: CCS - ACM Conference on Computer and Communications Security

Full text not available from this repository.

Abstract

The Web has become a platform in which applications rely on intricate interactions that span across the boundaries of origins. While the Same-Origin Policy prevents direct data exchange with documents from other origins, the postMessage API offers one relaxation that allows developers to exchange data across these boundaries nevertheless. While prior manual analysis efforts have already shown the presence of issues within postMessage handlers, unfortunately, a steep increase in postMessage usage makes any manual approach intractable. To deal with this increased analysis work load, we set out to automatically find issues in postMessage handlers that allow an attacker to execute code

in the vulnerable sites, alter its client-side state, or leak sensitive information. To achieve this goal, we present an automated analysis framework running inside the browser, which uses selective force execution paired with lightweight dynamic taint tracking to find traces in the analyzed handlers that end in sinks allowing for code-execution or state alterations. We use path constraints extracted from the program traces and augment them with Exploit Templates, i.e., additional constraints, ascertaining that a valid assignment that solves all these constraints produces a code-invoking or state-manipulating behavior. Based on these constraints, we use Z3 to generate postMessages aimed at triggering the insecure functionality to prove exploitability, and validate our findings at scale. We use this framework to conduct the most comprehensive experiment studying the security issues of postMessage handlers found throughout the top 100,000 most influential sites yet, which allows us to find potentially exploitable data flows in 252 unique handlers out of which 111 were automatically exploitable.

| Item Type: | Conference or Workshop Item (Paper) | | Divisions: | [Secure Web Applications Group \(SWAG\)](#) | | Conference: | CCS - ACM Conference on Computer and Communications Security | | Depositing User: | Ben Stock | | Date Deposited: | 29 Jul 2020 17:21 | | Last Modified: | 29 Jul 2020 17:21 | | URI: | <https://publications.cispa.saarland/id/eprint/3164> | |